Acme Enterprise AI - Security & Compliance Framework

SOC2 Type II | ISO 27001 Certified | GDPR & HIPAA Compliant

1. Encryption Standards

All data in transit is encrypted using TLS 1.3 with AES-256-GCM cipher suites. Data at rest, including vector embeddings in ChromaDB and session history in SQLite, is encrypted using AES-256 with keys managed in AWS KMS or HashiCorp Vault. Key rotation occurs automatically every 90 days.

2. Zero Data Retention (ZDR) for LLM Providers

All interactions with OpenAI or external foundation models pass through an enterprise proxy with Zero Data Retention. User prompts and document excerpts are never stored on OpenAI servers and are never utilized for model training. Direct consumer-grade API keys that lack ZDR agreements are strictly prohibited in production environments.

3. User Access Control and Multi-Tenancy

User authentication is enforced via OAuth2 with JWT access tokens signed by RS256. Multi-tenant database tables, including application_logs, require strict row-level security (RLS) filtering by session_id and organization_id to prevent unauthorized cross-tenant data leakage.